



Classic Web Security

장서현

카카오톡: d1n0

discord: d1n_0

email: d1n_0@korea.ac.kr

AI

- 요새 내 동년배들 다 AI 쓴다...
- 왜 해킹을 공부하는지 생각해 볼 타이밍
- 계산기를 초등학교부터 쓰면 구구단은 어떻게 외우나요

PHP

- 웹 서버 측 스크립트 언어
- HTML, CSS, JS만으론 부족
- php 파일을 동적으로 해석
- Apache?
 - 클라이언트 → 웹 서버 → PHP



Why PHP

- 웹 해커에게 PHP는 기본 소양
- 1995년부터 사용된 유구한 역사
- 아직도 아직도 종종 사용됨
- 웹 해커들이 좋아함 → CTF에 자주 나옴
 - 끝없이 발견되는 말도 안 되는 트릭들
 - 웹해킹의 역사는 PHP의 역사
 - `git clone https://github.com/php/php-src.git`



PHP를 배워보자

- 어느 세월에 다 가르치나요

PHP로 직접 로그인, 회원가입, 게시물 쓰기(파일 첨부 포함) 등 구현

- 강의를 중단하고 공부하고 오기
- 필수 개념
 - PHP에서 session을 어떻게 사용하는가
 - PHP에서 파일에 어떻게 접근하는가
 - PHP에서 코드 분할(예: python의 import)을 어떻게 하는가
 - PHP에서 쉘 명령어를 어떻게 실행하는가
 - PHP에서 DB와 어떻게 상호작용 하는가

LFI

Q. PHP에서 코드 분할을 어떻게 하는가

A. include / require / include_once / require_once

- 1. 공격자가 파일을 upload 폴더에 올릴 수 있음**
- 2. 로그 등 서버 파일 중 공격자의 입력 일부가 들어가는 경우가 있음**
- 3. ...**

RFI

- include에 웹 url이 들어갈 수 있던 시절이 있었다
- 현재 기본값 off

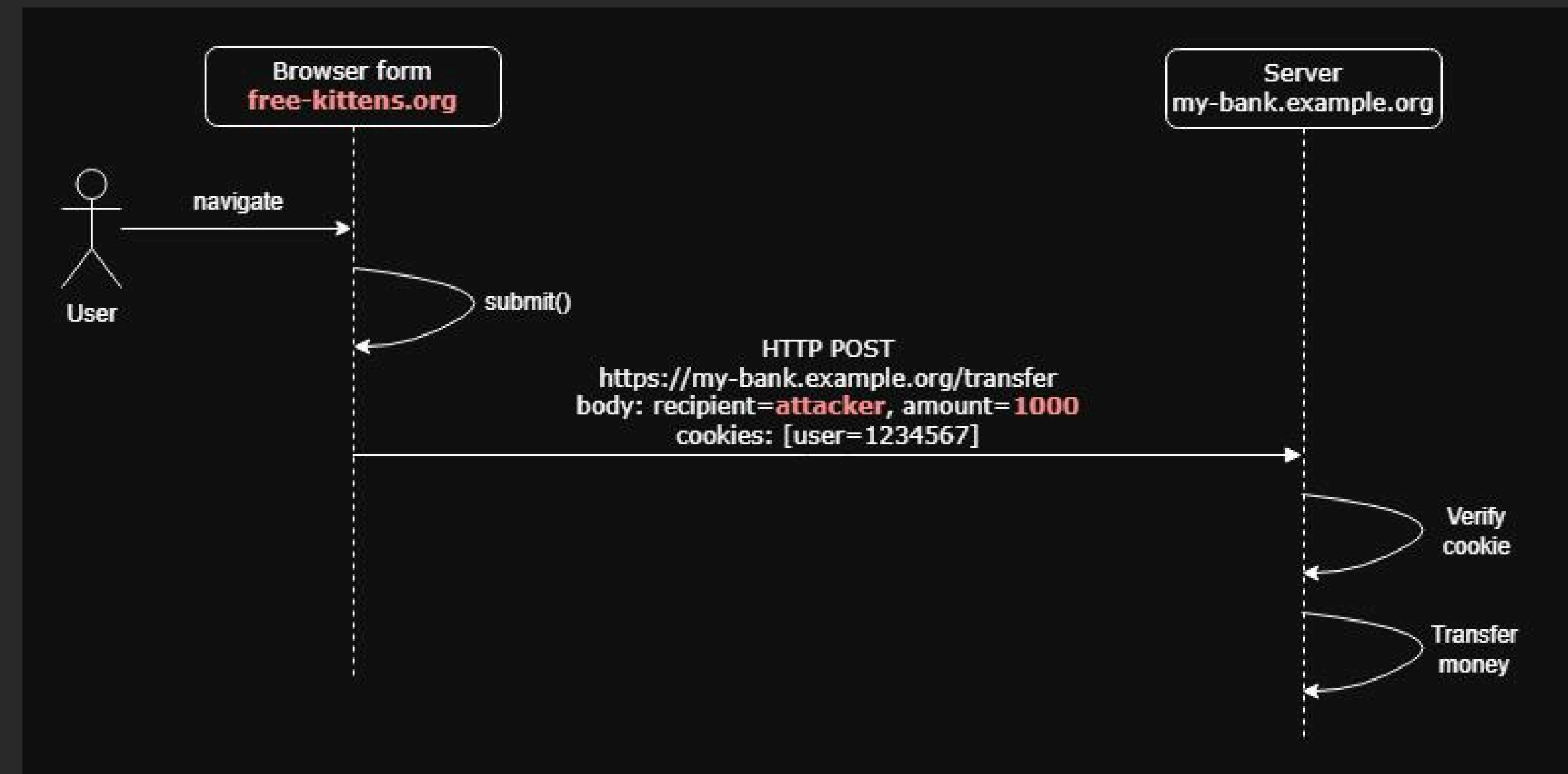
Directive	Local Value	Master Value
allow_url_fopen	On	On
allow_url_include	Off	Off

Path traversal

- `open(f"uploads/{filename}")`
- 만약 `filename=../../../../etc/passwd`라면?

CSRF

- Cross-Site Request Forgery



SSRF

- **Server-Side Request Forgery**

Command Injection

- `system(f"ping {ip}")`
- 만약 `ip=; cat /flag` 라면?

예제

Assignment

- 8/14 23:59까지
- 첨부된 예제 전부 풀기
 - 익스 코드 + 간단 설명 정도의 writeup
- 채팅 서비스 구현하기

Assignment

매우 안전한 채팅 서비스 구현하기

- 앞에서 만든 PHP 공부용 게시판에 이어서 만들면 됨
- APM (Apache, PHP, MySQL) 사용
- docker compose up으로 바로 실행되게
- 클라이언트 구현을 위해 javascript가 필요할 것
- AI의 도움을 받아도 됨
 - 작성한 코드를 AI한테 주고 보안상 위험을 발견
- 어떤 수정 과정이 있었는지 보고서에 제출
 - 솔직히 보고서는 사람이 직접 쓰자
- AI를 사용한다면 전후에 반드시 커밋
 - AI가 작업한 커밋에는 사용한 AI를 공동작업자로 명시

Assignment

1. 회원가입, 로그인, 로그아웃, 친구추가
2. 실시간 채팅 (websocket)
 - a. 이미지 첨부
 - b. 파일 첨부
 - c. url 첨부
 - i. 반드시 curl 명령으로 웹사이트를 읽은 후 미리보기 표시

세부 구현사항은 자유, 디자인은 신경쓰지 말 것

Assignment

1. 회원가입, 로그인, 로그아웃, 친구추가
2. 실시간 채팅 (websocket)
 - a. 이미지 첨부
 - b. 파일 첨부
 - c. url 첨부
 - i. 반드시 curl 명령으로 웹사이트를 읽은 후 미리보기 표시

세부 구현사항은 자유, 디자인은 신경쓰지 말 것